ET AI HACKATHON · AGENTIC EDITION · PROBLEM 2



PromptShield

A prompt-injection firewall for AI agents.

It checks untrusted text and files before the model sees them,
neutralises the hidden instruction, and still lets the ordinary text through.

GitHub

https://github.com/Sohamsurve/PromptShield

The problem

Agents treat retrieved content as instructions.

01

Hidden instruction

A line in an email, PDF, or web page can override the task the user actually asked for.

02

Side effect

The same line can ask the agent to reveal a secret or call a tool such as send-email.

03

Wrong tool

A toxicity filter does not catch this. Tool permissions still matter, and this firewall does not replace them.

What the prototype does

Scan first

Every prompt and file is checked before it reaches the agent.

Redact the span

Only the offending sentence is removed. The rest of the document stays.

Safe alternative

On block or quarantine, the caller gets the benign remainder, not the attack.

Tool firewall

A tainted send-email is denied even when text scanning is switched off.

Five answers

- **Allowed**
- **Sanitised**
- **Quarantined**
- **Blocked**
- **Needs review**

How one scan works

1	**Extract**	Text, HTML, PDF, Word, email, Markdown, JSON, source, and images. Hidden text is surfaced.
2	**Detect**	Signatures first, then a small classifier. Encoded text is decoded, with a depth cap.
3	**Decide**	Fusion picks the verdict. The language-model judge never decides alone.
4	**Neutralise**	The span is redacted in the original text. A second scan checks the result.
5	**Guard tools**	Before a side effect, the tool firewall checks taint, destination, and canaries.

What the video shows

01

Landing

One specimen email. Ultraviolet marks only the hidden instruction.

02

Arena

The same email, firewall off and on. The unprotected agent follows the hidden line.

03

X-ray

Revealed view, reason codes, and the safe alternative without the canary.

04

Clean pass

A normal security article stays Allowed.

05

Last line

Text scanning off. A tainted send-email is still denied.

06

Accounts

A caller scans a file. An admin sees each account’s usage.

Measured on the frozen golden suite

Judge off. Shipped policy. 11 October 2026. Not tuned on these rows.

0.61	0.48	0 / 500	26 ms
Acted recall	**Correct type**	**False positives**	**Latency p95**
900 attacks	900 attacks	Ordinary documents	Without the judge

Caught in full

Indirect injection, 100 of 100 on this suite.

Still weak

Multi-step jailbreaks: acted 0.35, correct type 0.00.

Other pack

Imported sentences: acted 0.18, false positives 0 of 32.

Full table: docs/CLAIMS.md · Report: eval/golden/reports/20261011T090211Z

What we declare

F1 / D1

Provisional. Nine attack types and the listed formats are in the product. An independent sealed run has not been scored.

Not claimed

F3 and D3. Known-pattern recall of 0.95. Held-out recall of 0.85. A length-matched false-positive rate at or under 2 percent.

Exact white-on-white text is not in the pixels, so OCR cannot read it.

The Arena agent is scripted. A live language-model agent was not the measured subject.

The judge can add a finding. It cannot block a document by itself.



PromptShield

Check the content. Remove the attack. Keep the document.

GitHub

https://github.com/Sohamsurve/PromptShield